DATA 6550 — Digital Privacy Agreement Audit

PRIVACY POLICY COMPARATIVE ANALYSIS MATRIX

Step 7: Regulatory Comparison & Comparative Analysis — All 12 Group Services

Group Project 6 | April 2026 | Fetterman · Kleinman · Otuonye · Price | Services: Comfrt · Apple · Venmo · Cash App · Notion · TikTok · Chase · Discord · Google · Microsoft · Netflix · Capital One

Made by Claude AI

How to Read This Matrix

Each service is evaluated across six matrices using consistent symbols: ✓ = Yes/Fully Present, △ = Partial/Conditional, ✗ = No/Not Addressed, N/A = Not Applicable. Rating rows at the bottom of each matrix summarize the overall posture for that focus area. The four required focus areas (Data Collection, User Rights, Data Sharing, Security) correspond to Matrices 1–4. Matrices 5–7 cover Regulatory Compliance, User-Friendliness, and the Overall Rankings summary.

✓ Yes / Fully Present	△ Partial / Conditional	✗ No / Not Addressed	**N/A** Not Applicable	**Excellent / Good** Strong compliance	**Adequate / Poor** Gaps present

Matrix 1 — Data Collection Practices

Assesses what types of personal data each service collects, how it is collected, and whether purposes are clearly specified. ✓ = confirmed collected/present, △ = partially or conditionally collected, ✗ = not collected per policy.

Criteria / Feature	Comfrt	Apple	Venmo	Cash App	Notion	TikTok	Chase	Discord	Google	Microsoft	Netflix	Capital One
1A. Types of Data Collected												
Identity / Account Info	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Payment / Financial Data	✓	✓	✓	✓	✓	△	✓	✓	✓	✓	✓	✓
Government ID / SSN	△	✓	✓	✓	△	△	✓	✗	△	△	△	✓
Device Identifiers / IP	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Precise Location Data	△	✓	△	△	△	✓	△	△	✓	△	△	△
Behavioral / Usage Data	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓

User-Generated Content	△	△	△	△	✓	✓	△	✓	✓	△	△	△
Voice / Audio Data	✗	△	✗	✗	✗	△	✗	✓	✓	✓	✓	✗
Biometric Data	✗	✗	✗	✗	✗	✓	✗	✗	△	△	✗	✗
Health / Fitness Data	✗	✓	✗	✗	✗	✗	✗	✗	△	△	✗	✗
Inferred / Profiling Data	✓	△	✓	✓	✓	✓	✓	△	✓	✓	✓	✓
Transaction / Purchase History	✓	✓	✓	✓	△	△	✓	△	✓	✓	✓	✓
Social Connections / Contacts	✗	△	✓	△	✗	✓	✗	✓	✓	✓	✗	✗
1B. Collection Methods												
Direct User Input	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓

Automatic / Telemetry	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Cookies & Web Beacons	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Third-Party / Data Brokers	✓	✓	✓	✓	△	✓	✓	△	✓	✓	✓	✓
Credit Bureau / Financial Data	✗	✗	✓	✓	✗	✗	✓	✗	✗	✗	✗	✓
Pre-Upload Content Scanning	✗	✗	✗	✗	✗	✓	✗	✗	✗	✗	✗	✗
Clipboard Access	✗	✗	✗	✗	✗	✓	✗	✗	✗	✗	✗	✗
1C. Purpose Specification												
Service Delivery	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Fraud Prevention / Security	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓

Marketing / Advertising	✓	△	✓	✓	✓	✓	✓	△	✓	✓	✓	✓
Personalization	△	✓	✓	△	✓	✓	✓	△	✓	✓	✓	✓
AI / ML Model Training	△	△	✗	✗	✗	✓	△	✗	✓	✓	✗	△
Purposes Clearly Specified	✓	✓	✓	△	✓	△	✓	✓	✓	✓	✓	✓
Data Collection Risk	△ Broad	✓ Controlled	△ Broad	△ Broad	✓ Controlled	✗ Extensive	△ Broad	△ Broad	✗ Extensive	△ Broad	△ Broad	△ Broad

Analysis — Data Collection

Most Extensive: Google and TikTok. Google collects across all its services simultaneously (search, email, maps, video, payments). TikTok adds biometrics, pre-upload scanning, and clipboard access — the most invasive collection method in this group.

Most Restrained: Apple and Notion. Apple collects health/fitness data but only with explicit opt-in; its "data minimization" philosophy is the most clearly stated of all 12. Notion limits collection to workspace productivity data with no advertising partnerships.

Financial Services Gap: Cash App and Capital One collect government IDs and financial history but provide the least clear purpose specification of any group in this audit. The GLBA financial data exemption means CCPA correction rights do not apply to their core data.

Common Pattern Across All 12: Every service collects device identifiers and behavioral/usage data — even services that claim minimal data collection can theoretically de-anonymize users through device fingerprinting.

TikTok's pre-upload content scanning — processing your content before you even decide to post it — is unique among these 12 services and raises significant consent questions not addressed in the policy.

Matrix 2 — Data Sharing Policies

Assesses who each service shares data with and under what conditions. △ for data sale means sharing that may qualify as a "sale" under the broad CCPA definition even if no money changes hands.

Criteria / Feature	Comfrt	Apple	Venmo	Cash App	Notion	TikTok	Chase	Discord	Google	Microsoft	Netflix	Capital One
2A. Third-Party Sharing												
Third-Party Service Providers	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Advertising / Ad Networks	✓	△	✓	✓	✗	✓	✓	△	✓	✓	✓	✓
Analytics Providers	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Business / Co-Brand Partners	△	✓	✓	✓	△	✓	✓	△	✓	✓	✓	✓
Corporate Affiliates	△	△	✓	✓	△	✓	✓	△	✓	✓	△	✓

Legal / Government Disclosure	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Acquirer / M&A Transfers	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Purchases from Data Brokers	✗	✗	✗	✗	✗	✗	✗	✗	✗	✓	✗	✗
Sells Personal Data	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗
2B. International Transfers												
International Transfers Disclosed	△	✓	△	✗	✓	✓	△	✓	✓	✓	△	△
EU-US Data Privacy Framework (DPF)	✗	✗	✗	✗	✓	✗	✗	✓	✓	✓	△	✗
Standard Contractual Clauses (SCCs)	✗	✓	✗	✗	✓	✗	✗	✓	✓	✓	✗	✗

APEC CBPR Certification	✗	✓	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗
2C. Service Provider Requirements												
Contracts Required with SPs	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
SPs Cannot Use Data for Own Purposes	△	✓	△	△	✓	△	△	✓	✓	✓	△	△
Sub-Processor Management Disclosed	✗	△	✗	✗	✓	△	✗	✓	✓	✓	△	✗
PCI-DSS for Payment Data	✓	✓	✓	✓	✓	△	✓	✓	✓	✓	✓	✓
Data Sharing Risk	△ Medium	✓ Low	△ Medium	△ Medium	✓ Low	✗ High	△ Medium	✓ Low	△ Medium	△ Medium	△ Medium	△ Medium

Analysis — Data Sharing

No service in this group admits to selling personal data in the traditional sense. However, sharing for advertising purposes creates similar practical outcomes for users — particularly for TikTok, Netflix, and Capital One.

Microsoft is the only service in this audit that explicitly admits to purchasing data from third-party data brokers to supplement what it collects directly — a practice no other policy in this group discloses.

Lowest Sharing Risk: Apple, Notion, and Discord. Apple contractually prevents service providers from using data for their own purposes. Discord funds through subscriptions, not ads, meaning no ad network data flows. Notion has no advertising partnerships.

International Transfers: Apple (SCCs + CBPR), Microsoft (EU-US DPF + UK Extension + Swiss-US), and Notion (Data Privacy Framework) have the most robust cross-border transfer mechanisms. Cash App and Capital One provide no international transfer documentation.

Law enforcement: All 12 services disclose personal data to law enforcement upon valid legal process. Discord and Microsoft have the most transparent policies, with published transparency reports.

Matrix 3 — User Rights

Assesses the depth and accessibility of user rights. Scored out of 5 (✓ = 1pt, △ = 0.5pt, ✗ = 0pt). N/A = Not Applicable. DNT (Do Not Track) is not honored by any of the 12 services, consistent with the current industry norm as no legal requirement exists to honor it.

Criteria / Feature	Comfrt	Apple	Venmo	Cash App	Notion	TikTok	Chase	Discord	Google	Microsoft	Netflix	Capital One
3A. Access Rights												
Right to Know / Access	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Self-Service Privacy Portal	△	✓	△	△	△	✓	△	✓	✓	✓	△	△
Right to Correct / Rectify	✓	✓	✓	△	✓	△	△	✓	✓	✓	△	△

Non-Discrimination for Exercising	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
3B. Deletion Rights												
Right to Delete Account	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Right to Delete Specific Data	✓	✓	△	△	✓	△	△	✓	✓	✓	△	△
Exceptions to Deletion Disclosed	✓	✓	✓	✓	✓	△	✓	✓	✓	✓	△	✓
3C. Portability Options												
Data Download / Export Tool	✗	✓	△	✗	✓	△	✗	✓	✓	✓	△	✗
Machine-Readable Format Offered	✗	△	✗	✗	✓	✗	✗	✓	✓	✓	✗	✗
3D. Opt-Out Mechanisms												

Opt-Out of Marketing Emails	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Opt-Out of Targeted Advertising	✓	✓	✓	✓	✓	△	✓	△	✓	✓	✓	✓
Opt-Out of Data Sharing / Sale	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Opt-Out of AI / Profiling	△	✓	△	✗	△	△	✗	△	✓	✓	△	✗
Cookie Opt-Out Tool Available	✓	✓	✓	✓	✓	△	✓	✓	✓	✓	✓	✓
Online Opt-Out Form Available	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Do Not Track (DNT) Honored	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗
Appeal Rights for Denied Requests	✓	✓	✓	△	✓	✓	✓	✓	✓	✓	✓	✓
User Rights Score (/5)	3.5/5 Good	4.5/5 Strong	3.5/5 Good	3.0/5 Fair	4.0/5 Good	3.5/5 Good	3.5/5 Good	4.5/5 Strong	5/5 Best	5/5 Best	3.5/5 Good	3.5/5 Good

Analysis — User Rights

Best Practice (5/5): Google and Microsoft. Google provides Dashboard, My Activity, Google Takeout, and Privacy Checkup all accessible from a single account page. Microsoft's Privacy Dashboard matches this comprehensiveness. Both are the gold standard for user rights infrastructure.

Strong (4.5/5): Apple and Discord. Apple's privacy.apple.com portal supports access, correction, deletion, and download globally. Discord provides a 30-day data download in JSON format and formal GDPR rights via a DPO.

Weakest Portability: Comfrt, Cash App, Chase, and Capital One — none offer a structured data export tool. Users must submit formal requests with no guaranteed export format.

Critical Gap — Correction Rights: Most services allow profile edits but lack formal correction request workflows for backend inaccuracies. Only Google, Microsoft, Apple, and Steam implement this properly.

Do Not Track: None of the 12 services honor the DNT browser signal. This is an industry-wide norm, not unique to this group — but worth documenting as a universal user control gap.

Matrix 4 — Security Measures

Assesses documented security practices including storage, protection methods, breach notification, and data retention. Scored out of 5.

Criteria / Feature	Comfrt	Apple	Venmo	Cash App	Notion	TikTok	Chase	Discord	Google	Microsoft	Netflix	Capital One
4A. Storage Practices												
Storage Location Disclosed	△	✓	△	✗	△	✓	△	✓	✓	✓	△	△

Data Minimization Principle Stated	△	✓	△	△	✓	△	△	✓	✓	✓	△	△
Payment Data via Third-Party Processor	✓	△	△	✓	✓	△	△	✓	△	△	✓	△
4B. Protection Methods												
Administrative Safeguards Stated	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Technical Safeguards Stated	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Physical Safeguards Stated	✓	✓	✓	✓	✓	△	✓	✓	✓	✓	✓	✓
Encryption at Rest Explicitly Stated	✗	△	✗	✗	✗	✗	✓	✓	✓	✓	✗	✗
Encryption in Transit Explicitly Stated	✗	△	✗	✗	✗	✗	✓	✓	✓	✓	✗	✗
Two-Factor Authentication (2FA)	✗	✓	✓	✓	✓	✓	✓	△	✓	✓	△	✓

Security Certifications Held	✗	△	✗	✗	✓	✗	✓	△	✓	✓	✗	✓
Data Protection Officer (DPO) Appointed	✗	✓	✗	✗	✓	✗	✗	✓	✓	✓	✓	✗
4C. Breach Notification												
Breach Notification Policy Stated	△	✓	△	△	✓	△	✓	✓	✓	✓	△	△
Specific Notification Timeline Given	✗	✗	✗	✗	✓	✗	△	✓	✓	✓	✗	✗
Regulatory Escalation Path Stated	✓	✓	△	△	✓	△	✓	✓	✓	✓	✓	△
4D. Data Retention												
Retention Policy Exists	△	✓	✓	△	✓	✓	△	✓	✓	✓	△	△
Specific Retention Periods Defined	✗	✓	✗	✗	✓	△	✗	✓	✓	✓	✗	✗

Data Deleted After Account Closure	△	✓	△	△	✓	△	△	✓	✓	✓	△	△
Legal Hold Exceptions Disclosed	✓	✓	✓	✓	✓	△	✓	✓	✓	✓	△	✓
Security Score (/5)	2.5/5 Adequate	4.5/5 Strong	2.5/5 Adequate	2.5/5 Adequate	4.0/5 Good	2.5/5 Adequate	5/5 Excellent	4.0/5 Good	5/5 Excellent	5/5 Excellent	2.5/5 Adequate	3.0/5 Good

Analysis — Security Measures

Best (5/5): Chase, Google, and Microsoft. Chase benefits from GLBA's mandatory Safeguards Rule, requiring a formal written information security program — a baseline that technology platforms are not legally required to maintain. Google and Microsoft both explicitly confirm encryption at rest and in transit.

Most Concerning: Comfrt, Venmo, Cash App, TikTok, Netflix — none confirm encryption at rest, have no DPO, and provide no specific breach notification timeline. For financial and entertainment platforms handling payment data, this is a significant gap.

Encryption Disclosure Gap: Only Google, Microsoft, Chase, and Discord explicitly state they use encryption at rest and in transit. The other 8 use vague language like "industry-standard safeguards" without specifying whether encryption is applied.

DPO Appointment: Apple, Notion, Discord, Google, Microsoft, and Netflix have appointed Data Protection Officers. The six financial/retail services (Comfrt, Venmo, Cash App, Chase, Capital One, TikTok) have none.

Retention Specificity: Most services state data is retained "as long as necessary" without defining specific periods per data type. Only Apple, Notion, Discord, Google, and Microsoft provide concrete retention frameworks.

Matrix 5 — Regulatory Compliance

Compares each service against key privacy regulations: CCPA/CPRA (California), GLBA (US Federal — Financial), GDPR (EU/EEA), VCDPA (Virginia), and applicable US state laws.

Criteria / Feature	Comfrt	Apple	Venmo	Cash App	Notion	TikTok	Chase	Discord	Google	Microsoft	Netflix	Capital One
CCPA / CPRA	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
GLBA (Financial Institutions)	✗	✗	✓	✓	✗	✗	✓	✗	✗	✗	✗	✓
GDPR (EU / EEA)	△	✓	✗	✗	✓	✗	✗	✓	✓	✓	△	✗
VCDPA (Virginia)	✓	△	✓	△	✓	△	△	✓	✓	✓	✓	✓
Multi-State US Privacy Laws	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
COPPA (Children 13+)	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Consumer Health Data Laws	✗	✓	✗	✗	✗	✓	✗	✗	✓	✓	✗	✗
Notice at Collection Provided	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓

Privacy Contact Provided	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Compliance Assessment	Good	Excellent	Good	Good	Excellent	Fair	Good	Good	Excellent	Excellent	Good	Good

Analysis — Regulatory Compliance

CCPA: All 12 services address CCPA requirements — expected given the broad scope of the law and the California-based operations of most tech companies.

GLBA: Only the four financial services (Venmo/PayPal, Cash App/Block, Chase, Capital One) are covered. GLBA-covered financial data is EXEMPT from CCPA rights — a major user protection gap that is not clearly communicated to customers.

GDPR: Apple, Notion, Discord, Google, and Microsoft have formal GDPR compliance programs. Netflix partially complies. The six remaining services (Comfrt, Venmo, Cash App, TikTok, Chase, Capital One) are primarily US-focused with limited or no EU privacy infrastructure.

TikTok's Fair rating reflects ongoing regulatory concern about its USDS Joint Venture structure and data governance practices, as well as the absence of a formal DPO or EU-US DPF certification.

Chase's policy has not been updated since September 2023 — the oldest policy in this group and the only one flagged as aging relative to current regulatory developments.

Matrix 6 — User-Friendliness Assessment

Assesses how understandable and actionable each privacy policy is for an average user. Scored out of 5. This goes beyond legal compliance to evaluate practical accessibility.

Criteria / Feature	Comfrt	Apple	Venmo	Cash App	Notion	TikTok	Chase	Discord	Google	Microsoft	Netflix	Capital One
Plain Language Used	✓	✓	✓	△	✓	✓	△	✓	✓	✓	✓	△
Table of Contents / Navigation	✓	✓	△	✗	✓	✓	△	✓	✓	✓	△	△
Summary / Plain-Language Overview	✗	✗	✗	✗	✗	✓	✗	✓	△	✗	✗	✗
Layered / Tiered Disclosure	✗	✓	✗	✗	✗	△	✗	✓	✓	△	✗	✗
Examples / Explanatory Notes	△	✓	△	✗	△	△	△	✓	✓	✓	△	△
Visual Aids / Icons Used	✗	✓	✗	✗	✗	✗	✗	✗	✓	✗	✗	✗
Policy Reasonably Concise	✓	△	△	✓	△	△	△	✓	△	△	△	△
Readable at General Audience Level	✓	✓	✓	△	✓	✓	△	✓	✓	✓	✓	△

Privacy Settings Easily Accessible	△	✓	✓	✓	✓	△	△	✓	✓	✓	△	△
Policy Updated Within 2 Years	✓	✓	✓	✓	✓	✓	✗	✓	✓	✓	✓	✓
User-Friendliness Score (/5)	3/5 Good	4.5/5 Excellent	3/5 Good	2/5 Difficult	3.5/5 Good	3/5 Good	2.5/5 Moderate	4/5 Good	4.5/5 Excellent	3.5/5 Good	2.5/5 Moderate	2/5 Difficult

Analysis — User-Friendliness

Best Practice: Apple and Google (4.5/5 each). Apple uses layered disclosure with Data & Privacy icons embedded in products. Google provides explanatory videos, plain-language summaries, and an interactive Privacy Checkup tool.

Strong: Discord (4/5). Written at a high school reading level with a plain-language summary up front and self-service privacy settings built directly into the platform — the clearest policy structure of any social/communication platform in this group.

Most Difficult: Cash App and Capital One (2/5). GLBA-formatted notices are dense, legalistic, and structured for regulatory compliance disclosure rather than comprehension. Capital One requires users to navigate multiple separate policy documents to understand their full rights.

Chase is the only service with a policy that has not been updated within 2 years (last updated September 2023) — flagged as a concern given the pace of US state privacy law changes since then.

None of the 12 services provides a plain-language one-page summary of the five most important things a user is agreeing to at the moment of account creation — the intervention that would most benefit users across the board.

Matrix 7 — Overall Rankings Summary

Aggregates findings across Matrices 1–6 into a final ranked comparison. Grades reflect the composite of regulatory compliance, data collection scope, sharing risk, user rights, security, and user-friendliness.

Grade Scale: A = Best Practice / Excellent | B = Good / Adequate | C = Below Average / Fair | D = Poor

Criteria / Feature	Comfrt	Apple	Venmo	Cash App	Notion	TikTok	Chase	Discord	Google	Microsoft	Netflix	Capital One
Regulatory Compliance	Good	Excellent	Good	Good	Excellent	Fair	Good	Good	Excellent	Excellent	Good	Good
Data Collection Risk	△ Broad	✓ Controlled	△ Broad	△ Broad	✓ Controlled	✗ Extensive	△ Broad	△ Broad	✗ Extensive	△ Broad	△ Broad	△ Broad
Data Sharing Risk	Medium	Low	Medium	Medium	Low	High	Medium	Low	Medium	Medium	Medium	Medium
User Rights Score	3.5/5	4.5/5	3.5/5	3.0/5	4.0/5	3.5/5	3.5/5	4.5/5	5/5	5/5	3.5/5	3.5/5
Security Score	2.5/5	4.5/5	2.5/5	2.5/5	4.0/5	2.5/5	5/5	4.0/5	5/5	5/5	2.5/5	3.0/5
User-Friendliness	3/5	4.5/5	3/5	2/5	3.5/5	3/5	2.5/5	4/5	4.5/5	3.5/5	2.5/5	2/5
OVERALL VERDICT	**B- Fair**	**A Excellent**	**B Good**	**C+ Fair**	**B+ Good**	**D Poor**	**B+ Good**	**B+ Good**	**A- Good**	**A- Excellent**	**B Good**	**B Good**

Overall Findings

#1 Apple — Best-in-class across data minimization, user rights infrastructure, transparency, and international compliance. The only service in this group with CBPR certification and a formal no-profiling-without-human-review commitment.

#2 Google & Microsoft (tied) — Strongest user controls and compliance posture of any high-volume data collectors. Both lose points for data breadth (Google cross-product tracking; Microsoft data broker purchases) but lead in rights infrastructure.

#4 Discord & Notion — Top performers among social/productivity platforms. Discord's subscription model eliminates ad network data sharing entirely. Notion's GDPR + Data Privacy Framework dual compliance exceeds what most SaaS platforms provide.

#6 Chase & Netflix — Strong regulatory foundation (GLBA for Chase; US state law compliance for Netflix) but limited portability, aging policy (Chase), and broad data sharing for advertising (Netflix) hold both at B.

#8 Venmo, Comfrt, TikTok — Venmo and Cash App are constrained by GLBA structure. Comfrt is a small retail site doing more than expected but lacks digital rights infrastructure. TikTok is the only D-rated service — biometric collection, pre-upload scanning, and clipboard access combined with limited GDPR compliance are the primary concerns.